

SOC PLAYBOOK 2026

**SIGNAL → CONTEXT →
BEHAVIOUR →
TIMELINE → RISK →
DECISION**

BY IZZMIER IZZUDDIN

SCENARIO 1 — IDENTITY-BASED INITIAL ACCESS → LIVING-OFF-THE-LAND → CLOUD DATA EXFILTRATION

Scenario

Item	Details
Attack Theme	Identity compromise + Living-off-the-Land (LotL)
Initial Vector	Compromised O365 account (password reuse + MFA fatigue)
Environment	Hybrid (Cloud + Endpoint)
Objective	Silent data access and cloud exfiltration
Detection Style	Behavioural + timeline correlation
Typical SOC Failure	Alert closed as “Successful login”

1. SIGNAL

Raw detection. No judgement yet.

A signal is anything abnormal, not an alert to be closed.

Simulated Signals

Signal A — Cloud Authentication Log

Time: 2026-02-14 02:18:33 UTC

Source: AzureAD

Event: SignInLogs

User: finance.admin@company.com

Result: Success

MFA: Satisfied

IP Address: 185.212.44.19

Location: Bucharest, RO

Device: Unknown

Signal B — Endpoint Process Execution

Time: 2026-02-14 02:24:11 UTC

Host: FIN-LAP-023

User: finance.admin

Process: powershell.exe

CommandLine:

powershell -nop -w hidden -c "Invoke-WebRequest -Uri https://storage-live[.]blob.core.windows.net/temp/export.zip -OutFile C:\ProgramData\export.zip"

Parent Process: explorer.exe

At this stage:

- No severity assigned
- No closure
- No assumptions

2. CONTEXT

Who, where, what should be normal?

Context answers: Is this expected for this user, this device, this time, this location?

Enriched Context

Attribute	Observed	Expected
User Role	Finance Admin	High-risk privileged
Login Time	02:18 UTC	User normal hours: 09:00–18:00 MYT
Geo Location	Romania	User always logs in from Malaysia
Device	Unknown	Normally FIN-LAP-023 only
MFA Pattern	Push accepted	Multiple pushes before accept (see below)

Azure AD MFA Detail

MFA Attempts:

02:16:01 Push Sent - No Response

02:16:37 Push Sent - No Response

02:18:12 Push Sent - Approved

Context conclusion:

- This is not normal behaviour
- No justification exists yet

3. BEHAVIOUR

What is the user actually doing after access?

Behaviour is sequence, not single events.

Behavioural Indicators

Endpoint Behaviour

02:23 powershell.exe spawned by explorer.exe

02:24 outbound HTTPS to blob.core.windows.net
02:25 file written to ProgramData (hidden path)
02:26 powershell compress archive

Cloud Behaviour

02:19 SharePoint Online:

User accessed:

- /Finance/Board/2025-Audit.xlsx
- /Finance/Acquisition/Targets.docx
- /Finance/Payroll/Payroll_Q4.xlsx

No malware detected

No exploit used

All actions technically “allowed”

This is Living-off-the-Land abuse

4. TIMELINE

Reconstruct the attacker story

This is where SOC's must operate in 2026.

Attack Timeline Reconstruction

Time	Event
02:16	MFA push fatigue begins
02:18	MFA approved
02:18	Cloud login from new country
02:19	Sensitive SharePoint access
02:23	PowerShell execution
02:24	External cloud storage download
02:27	Data staged locally
02:31	HTTPS outbound spike

Timeline insight:

- Identity compromise occurred before endpoint activity
- Endpoint is used only as a data staging tool
- Cloud storage used as exfiltration proxy

5. RISK

Impact-focused, not alert-focused

Risk Assessment

Dimension	Assessment
Asset	Finance & M&A documents
Exposure	Confirmed access
Privilege Level	High
Stealth Level	High (no malware)
Regulatory Impact	High (financial data)
Business Impact	Severe

This is not suspicious

This is active compromise

6. DECISION

Clear, decisive SOC outcome

SOC Decision

Confirmed Security Incident — Identity Compromise with Data Exfiltration

Required Actions (Not Optional)

Immediate Containment

- Disable user account
- Revoke all active cloud sessions
- Block external blob storage domain temporarily
- Isolate endpoint FIN-LAP-023

Investigation Expansion

- Check other admin accounts for MFA fatigue
- Review all sign-ins from Romania IP range
- Inspect mailbox rules and OAuth grants

Business Notification

- Inform Finance Head
- Trigger IR process
- Preserve logs for legal review

SCENARIO 2 — API TOKEN ABUSE → SAAS-TO-SAAS DATA EXFILTRATION (NO USER LOGIN)

Scenario

Item	Details
Attack Theme	API token abuse
Initial Vector	Leaked OAuth token (GitHub / CI pipeline / vendor breach)
Environment	SaaS (M365 + Third-party SaaS)
Objective	Silent bulk data extraction
Detection Style	Behaviour + volume anomaly
Typical SOC Failure	“No login, no incident”

1. SIGNAL

Raw signals. No identity assumption.

Simulated Signals

Signal A — Microsoft Graph API Log

Time: 2026-03-03 01:12:44 UTC

Source: AzureAD

Event: AuditLogs

Operation: ListFiles

AppID: 9f83c2b1-xxxx-4d92

AppName: Finance-Automation-App

Result: Success

CallerIP: 104.28.211.87

AuthType: OAuth

Signal B — API Rate Anomaly

Time Window: 01:12 – 01:18 UTC

Requests: 18,432

Average Daily Baseline: 1,200

Target: SharePoint Online

At this point:

- No user
- No MFA
- No endpoint

Only machine-to-cloud activity

2. CONTEXT

What is this application supposed to do?

Context is business logic, not security logic.

Application Context

Attribute	Observed	Expected
App Type	Finance automation	Scheduled daily
Normal Time	09:00 UTC	Current: 01:00 UTC
API Scope	Read invoices only	Accessed M&A & HR
Source IP	Cloudflare ASN	Normally Azure Malaysia
Volume	18k requests	Normal < 1.5k

OAuth Scope Detail

Granted Scopes:

- Files.Read.All
- Sites.Read.All
- Mail.Read

This app is over-privileged.

3. BEHAVIOUR

What is the token doing that matters?

Behaviour answers:

Is this automation or harvesting?

Observed Behaviour

API Access Pattern

/Finance/Payroll/
/Finance/Board/
/Legal/Acquisition/
/HR/Executive/

Download Pattern

01:13 bulk file enumeration
01:14 parallel download threads
01:15 archive creation (client-side)
01:17 upload to external SaaS

This is systematic harvesting, not automation.

4. TIMELINE

Reconstruct the attacker's path

Attack Timeline

Time	Event
Day -14	OAuth token created
Day -12	Token committed to private repo
Day -1	Repo exposed via vendor breach
01:12	API abuse begins
01:18	18k files enumerated
01:21	External SaaS upload spike
01:24	Activity stops

Key insight:

- The attacker never touched a user account
- The breach existed weeks before detection
- SOC visibility started too late

5. RISK

Evaluate impact, not alerts

Risk Assessment

Dimension	Assessment
Data Sensitivity	Payroll, M&A, HR
Scope	Organisation-wide
Stealth	Very high
Detection Delay	14 days
Regulatory Impact	Critical
Business Impact	Severe

This is a confirmed data breach, not suspicious activity.

6. DECISION

Clear SOC judgement

SOC Decision

Confirmed Security Incident — OAuth Token Compromise & Data Exfiltration

Mandatory Actions

Immediate

- Revoke OAuth token
- Disable application registration
- Rotate all related secrets
- Block offending IP ranges

Investigation

- Audit all OAuth apps with Files.Read.All
- Identify other leaked tokens
- Review vendor access paths

Governance

- Enforce least-privilege OAuth scopes
- Implement API behaviour baselining
- Add SaaS-to-SaaS egress monitoring

SCENARIO 3 — INSIDER THREAT USING LEGITIMATE BACKUP & SYNC TOOLS (NO MALWARE, NO EXPLOIT)

Why this scenario matters in 2026

In 2025–2026, many major breaches are:

- Performed by legitimate users
- Using approved tools
- During approved access windows

This defeats SOC’s that rely on:

- Malware detection
- IOC-based alerts
- “Admin access = trusted”

Scenario

Item	Details
Attack Theme	Insider data exfiltration
Initial Vector	Legitimate user access
Tools Used	Approved backup / sync software
Environment	Endpoint + SaaS
Objective	Quiet bulk data removal
Detection Style	Behaviour + intent analysis
Typical SOC Failure	“User is authorised”

1. SIGNAL

Weak signals that look harmless alone

Simulated Signals

Signal A — Endpoint Software Activity

Time: 2026-04-11 21:46:12 MYT
Host: HR-LAP-011
User: hr.manager
Process: BackupSync.exe
Version: 4.2.1
Execution Type: Manual

Signal B — Network Transfer Spike

Time Window: 21:46–22:03

Destination: cloud-sync-storage[.]com

Protocol: HTTPS

Outbound Data: 14.8 GB

Baseline (HR user): < 500 MB/day

Signal C — SaaS Access

Time: 21:41

Source: SharePoint Online

User: hr.manager

Files Accessed:

- /HR/Payroll/Payroll_All.xlsx

- /HR/Disciplinary/2024_2025.docx

- /HR/Termination/Exit_List.pdf

No malware

No exploit

No security alert fired yet

2. CONTEXT

Is this normal for this person?

User Context

Attribute	Observed	Expected
Role	HR Manager	High data sensitivity
Working Hours	After-hours	Normally 09:00–18:00
Tool Usage	Manual backup	Normally scheduled
Data Type	Payroll, termination	Rare bulk access
Destination	Personal sync tenant	Never used before

Endpoint Context

Device: Corporate-managed

DLP Agent: Enabled

Action: Allowed (sanctioned app)

Context conclusion:

- Activity is technically allowed

- Behaviourally unusual

3. BEHAVIOUR

Intent emerges through sequence

Behavioural Pattern

21:40 Login

21:41 Sensitive HR folders accessed

21:44 Local folder staging created

21:46 BackupSync.exe manually launched

21:47–22:03 Continuous outbound upload

Behavioural Red Flags

- Manual trigger instead of schedule
- Bulk access across unrelated HR folders
- No corresponding HR process (no audit, no payroll cycle)
- Destination tied to personal account, not corporate tenant

This is intent-based misuse, not an accident.

4. TIMELINE

Build the insider story

Timeline Reconstruction

Time	Event
Day -7	HR resignation notice submitted
Day -2	Download attempts increase
Day 0 21:40	After-hours login
21:41	Sensitive HR documents accessed
21:46	Manual backup execution
22:03	Upload completed
22:05	User logs out

Critical insight:

- Activity aligns with pre-departure behaviour
- No business justification exists

5. RISK

Assess damage, not permissions

Risk Assessment

Dimension	Assessment
Data Type	Payroll, disciplinary
Exposure	Confirmed upload
Insider Status	Privileged
Intent	Likely malicious
Legal Impact	High
Reputational Risk	Severe

This is not “policy violation”

This is data theft

6. DECISION

SOC must act, not hesitate

SOC Decision

Confirmed Insider Data Exfiltration Incident

Required Actions

Immediate

- Disable user account
- Suspend backup tool access
- Block external sync destination
- Preserve endpoint image

Investigation

- Verify uploaded content
- Review prior 30 days of access
- Correlate HR exit timeline

Business Response

- Notify HR leadership
- Engage Legal & Compliance
- Initiate disciplinary / legal process

SCENARIO 4 — SAAS-TO-SAAS DATA EXFILTRATION USING SANCTIONED APPLICATIONS (NO ENDPOINT INVOLVED)

Scenario

Item	Details
Attack Theme	SaaS-to-SaaS data exfiltration
Initial Vector	Compromised cloud account
Tools Used	Approved SaaS (Google Drive / Dropbox / Box)
Environment	Cloud-only
Objective	Silent bulk data transfer
Detection Style	Behaviour + relationship analysis
Typical SOC Failure	“Sharing is allowed”

1. SIGNAL

Low-noise cloud-native signals

Simulated Signals

Signal A — Cloud Sharing Event

Time: 2026-05-09 03:14:22 UTC

Source: Microsoft 365

Event: FileShared

User: strategy.lead@company.com

Shared With: strategy.external@gmail.com

Permission: Edit

File:

- /Strategy/2026/Acquisition_Targets.xlsx

Signal B — Sync Activity

Time Window: 03:15–03:29

Source: Google Drive API

Operation: FileSync

Files Synced: 327

Total Size: 9.6 GB

No download

No upload from endpoint

Only sharing + sync

2. CONTEXT

Should this relationship exist?

Context in 2026 includes identity relationships, not just events.

User Context

Attribute	Observed	Expected
Role	Strategy Lead	High confidentiality
Sharing Target	Personal Gmail	Not approved
Time	03:00 UTC	User active hours 09:00–18:00
Sharing Pattern	Bulk	Normally selective
SaaS App	External tenant	Never used

Historical Context

Last 90 days:

External sharing events: 0

Context conclusion:

- This relationship is new
- No business justification exists

3. BEHAVIOUR

What is the data doing next?

Behaviour reveals intent, not permissions.

Observed Behaviour Sequence

03:12 Login from new device

03:14 High-sensitivity files shared

03:15 External SaaS sync initiated

03:16 Parallel cloud ingestion

03:29 Sync completed

Behavioural Indicators

- Immediate sync after sharing
- No collaboration activity (no edits, comments)
- Bulk data movement

This is transfer, not collaboration.

4. TIMELINE

Tell the full cloud story

Timeline Reconstruction

Time	Event
Day -3	OAuth access granted to Google Drive
Day 0 03:12	New device login
03:14	Sensitive files shared
03:15	External SaaS sync begins
03:29	Data transfer completed
03:31	Session ends

Key insight:

- OAuth trust was abused
- Endpoint never touched data

5. RISK

Business impact over technical noise

Risk Assessment

Dimension	Assessment
Data Type	Strategy, M&A
Exposure	Confirmed
Stealth Level	Very high
Detection Difficulty	High
Legal Impact	Severe
Competitive Risk	Critical

This is a confirmed data exfiltration incident.

6. DECISION

SOC must classify decisively

SOC Decision

Confirmed Cloud Data Exfiltration via Sanctioned SaaS

Required Actions

Immediate

- Disable compromised account
- Revoke OAuth grants
- Remove external sharing permissions
- Suspend external SaaS access

Investigation

- Review all external shares (90 days)
- Audit OAuth consent history
- Identify similar sharing relationships

Governance

- Restrict external sharing by sensitivity
- Implement cloud-to-cloud DLP
- Enforce OAuth app approval workflow

SCENARIO 5 — PRIVILEGED BACKUP SYSTEM ABUSE BY IT ADMINISTRATOR (TRUSTED ACCESS, MAXIMUM IMPACT)

Scenario

Item	Details
Attack Theme	Privileged misuse
Initial Vector	Compromised or rogue IT admin
Tools Used	Enterprise backup platform
Environment	Infrastructure + Storage
Objective	Full data extraction
Detection Style	Behaviour + intent analysis
Typical SOC Failure	“It’s a backup job”

1. SIGNAL

Nothing looks malicious at first glance

Simulated Signals

Signal A — Backup Job Execution

Time: 2026-06-18 01:32:09 MYT

Source: BackupSystem

Job Name: Manual_Full_Backup

Executed By: it.backup.admin

Target: DR-Storage-EXT

Result: Success

Signal B — Network Transfer

Time Window: 01:32–02:11

Protocol: HTTPS

Destination: external-object-storage[.]com

Outbound Volume: 3.4 TB

Baseline (backup jobs): 800 GB – 1.2 TB

No malware

No alert

No failed authentication

2. CONTEXT

Is this job justified?

Context answers why, not what.

Admin & Process Context

Attribute	Observed	Expected
Admin Role	Backup Admin	High privilege
Job Type	Manual full backup	Normally scheduled
Time	After-hours	Approved but rare
Destination	External tenant	DR normally internal
Change Record	None	Required

Process Context

Change Management System:

Approved DR test: None

Emergency ticket: None

Context conclusion:

- Technically allowed
- Procedurally unjustified

3. BEHAVIOUR

What is different from normal backups?

Behaviour highlights intent, not permission.

Behavioural Indicators

- Manual job execution
- External storage not registered as DR
- Full system images instead of incremental
- No restore validation
- Job deleted after completion

Backup Scope

Included:

- Core banking databases
- HR systems
- Email archives

- File servers

This is harvesting, not resilience.

4. TIMELINE

Reconstruct the abuse path

Timeline Reconstruction

Time	Event
Day -10	Admin resignation notice
Day -3	New external storage endpoint added
Day 0 01:32	Manual full backup triggered
02:11	Transfer completed
02:13	Job record deleted
02:15	Admin logs out

Key insight:

- Backup platform was used as an exfiltration engine
- SOC visibility relied on trust, not verification

5. RISK

This is worst-case exposure

Risk Assessment

Dimension	Assessment
Data Scope	Organisation-wide
Data Sensitivity	Maximum
Privilege Level	Highest
Detectability	Low
Regulatory Impact	Critical
Business Impact	Catastrophic

This is not misuse

This is enterprise-scale data theft

6. DECISION

SOC must overcome trust bias

SOC Decision

Confirmed Privileged Data Exfiltration via Backup System

Mandatory Actions

Immediate

- Suspend admin account
- Terminate active backup sessions
- Block external storage endpoints
- Preserve backup logs and images

Investigation

- Review all backup jobs (90 days)
- Audit admin activity across platforms
- Verify integrity of remaining backups

Governance

- Enforce dual control for backup execution
- Restrict backup destinations
- Monitor backup volume anomalies

SCENARIO 6 — SLOW-DRIP DATA THEFT BELOW DLP THRESHOLDS (LONG-TERM SILENT EXFILTRATION)

Scenario

Item	Details
Attack Theme	Low-and-slow exfiltration
Initial Vector	Compromised user credentials
Tools Used	Native apps, HTTPS
Environment	Endpoint + SaaS
Objective	Continuous data siphoning
Detection Style	Trend & behaviour analysis
Typical SOC Failure	“No alert threshold crossed”

1. SIGNAL

Nothing alarming in isolation

Simulated Signals (Daily)

Endpoint Activity

User: product.engineer

Host: ENG-LAP-044

Daily Upload Volume: 120–180 MB

Destination: personal-cloud-sync[.]com

Protocol: HTTPS

SaaS Activity

Source: SharePoint Online

Files Accessed: 5–12 per day

Categories:

- Design specs
- Source diagrams
- Architecture docs

Each event is below DLP alert thresholds.

2. CONTEXT

Is this pattern normal over time?

Context in 2026 includes historical behaviour, not just roles.

User Behaviour Context

Attribute	Observed	Baseline
Daily Upload	~150 MB	< 20 MB
Access Frequency	Daily	Weekly
Data Sensitivity	High	Medium
Destination	Personal tenant	Never used
Duration	43 days	N/A

No single violation

But cumulative deviation

3. BEHAVIOUR

Pattern reveals intent

Behavioural Pattern Over Time

Week 1: Test uploads (small files)

Week 2: Consistent daily transfers

Week 3: File naming sanitised

Week 4: Increased sensitivity of documents

Week 6: Activity continues unchanged

Indicators:

- No business milestones
- No collaboration behaviour
- No access justifications

This is systematic extraction.

4. TIMELINE

Long-term attacker patience

Timeline Reconstruction

Period	Activity
Day 0	Credential compromise
Day 3	First small upload
Day 14	Pattern stabilises

Day 30	High-value files included
Day 43	Detection via trend analysis

Key insight:

- Attackers traded speed for invisibility
- SOC detection delay = 43 days

5. RISK

Cumulative damage matters

Risk Assessment

Dimension	Assessment
Data Type	Intellectual property
Exposure	Partial but continuous
Stealth	Extremely high
Detection Difficulty	Very high
Business Impact	Strategic loss
Regulatory Impact	Moderate to high

This is a confirmed breach, not policy drift.

6. DECISION

SOC must think longitudinally

SOC Decision

Confirmed Long-Term Data Exfiltration Incident

Required Actions

Immediate

- Disable compromised credentials
- Block personal cloud destinations
- Force credential reset
- Isolate endpoint

Investigation

- Reconstruct full 43-day access history

- Identify copied files
- Check lateral access expansion

Governance

- Implement trend-based DLP
- Add rolling baseline alerts
- Restrict personal cloud usage

SCENARIO 7 — CROSS-TENANT IDENTITY FEDERATION ABUSE (TRUSTED PARTNER BECOMES THE ATTACK PATH)

Scenario

Item	Details
Attack Theme	Federated identity abuse
Initial Vector	Compromised partner tenant
Trust Mechanism	Azure AD B2B / federation
Environment	Cloud identity & SaaS
Objective	Silent access to sensitive data
Detection Style	Relationship + behaviour analysis
Typical SOC Failure	“Partner access is approved”

1. SIGNAL

Nothing looks suspicious on its own

Simulated Signals

Signal A — Federated Login

Time: 2026-08-02 01:54:11 UTC

Source: AzureAD SignInLogs

User: external.consultant@partnerco.com

Home Tenant: partnerco.onmicrosoft.com

Resource Tenant: company.onmicrosoft.com

Authentication: Federated

Result: Success

Signal B — SaaS Access

Time: 01:55–02:10

Service: SharePoint Online

Files Accessed:

- /Strategy/2026/Expansion_Plan.docx

- /Finance/Forecast_Q3.xlsx

- /Legal/Merger_Draft.pdf

No failed login

No MFA failure

No unusual IP

2. CONTEXT

Is this trust still valid?

Context in 2026 is relationship-based, not just user-based.

Federation Context

Attribute	Observed	Expected
Partner Role	Consultant	Limited scope
Access Duration	18 months	Contract ended
Data Accessed	Strategy & Finance	Outside scope
Time	After-hours	Normally business hours
Access Frequency	Bulk	Normally selective

Contract Context

Vendor Contract Status:

Expired: 4 months ago

Access Review: Not performed

Context conclusion:

- Trust exists technically
- Trust no longer exists legally

3. BEHAVIOUR

What is the federated identity doing?

Behavioural Pattern

01:54 Login

01:55 Immediate access to high-sensitivity folders

01:56 No collaboration actions

02:00 Continuous file access

02:10 Session ends

Indicators:

- No meeting context
- No document edits
- No comments or sharing

This is harvesting, not consulting.

4. TIMELINE

Reconstruct the trust abuse

Timeline Reconstruction

Time	Event
Month -18	Partner federation established
Month -6	Partner tenant compromised
Month -4	Contract expired
Day 0 01:54	Federated access begins
02:10	Data access completed
Day +12	SOC detects anomaly

Key insight:

- Breach originated outside your tenant
- Your logs show only “successful access”

5. RISK

Trust amplifies impact

Risk Assessment

Dimension	Assessment
Data Type	Strategy, finance, legal
Exposure	Confirmed access
Stealth	Extremely high
Detection Delay	Long
Regulatory Impact	High
Reputational Risk	Severe

This is a confirmed data breach via trust abuse.

6. DECISION

SOC must override “trusted” bias

SOC Decision

Confirmed Security Incident — Federated Identity Abuse

Required Actions

Immediate

- Disable federated access for partner tenant
- Revoke guest user sessions
- Restrict high-sensitivity SharePoint sites

Investigation

- Review all federated access (12 months)
- Audit partner tenant security posture
- Identify other stale trust relationships

Governance

- Enforce periodic access recertification
- Limit federated access by sensitivity
- Add behaviour-based alerts for guest users

SCENARIO 8 — SOC TOOLING MISUSE (SIEM / SOAR ABUSE TO HIDE MALICIOUS ACTIVITY)

Scenario

Item	Details
Attack Theme	Security tooling abuse
Initial Vector	Compromised SOC admin account
Tools Abused	SIEM, SOAR
Environment	SOC platform
Objective	Blind the SOC and hide activity
Detection Style	Meta-monitoring & integrity checks
Typical SOC Failure	“SOC tools are trusted”

1. SIGNAL

Subtle signals that SOC's rarely watch

Simulated Signals

Signal A — SIEM Rule Modification

Time: 2026-09-14 00:42:19 UTC

Source: SIEM_AuditLogs

Action: DetectionRuleUpdated

Rule Name: Suspicious_PowerShell_Execution

Modified By: soc.admin01

Change:

Severity: High → Low

Action: Alert → Log Only

Signal B — SOAR Playbook Change

Time: 00:44:07

Playbook: Auto_Isolate_Endpoint

Change:

Trigger Condition Removed:

IF UserRole = "Admin"

Signal C — Audit Logging Disabled

Time: 00:46:33

Component: CloudAuditLogs

Status: Disabled

Initiated By: soc.admin01

Individually, these look like maintenance.

2. CONTEXT

Should this person be doing this now?

Context in 2026 includes change intent, not just permission.

Admin Context

Attribute	Observed	Expected
Role	SOC Admin	High privilege
Time	Midnight	Change window not approved
Ticket	None	Mandatory
Scope	Multiple controls	Usually single
Peer Review	No	Required

HR Context

Recent Events:

- Admin reported suspicious MFA prompts (Day -1)
- Password reset not completed

Context conclusion:

- Changes are authorised but unjustified
- Timing correlates with suspicious activity

3. BEHAVIOUR

What happens after SOC visibility is reduced?

Behavioural Correlation

00:42 Detection rules weakened
00:44 SOAR containment disabled
00:46 Audit logs turned off
00:51 PowerShell execution spike
00:58 Outbound C2 traffic detected (network IDS)

Endpoint Behaviour (Now Visible Elsewhere)

Host: FIN-SRV-009

Process: powershell.exe

Command:

powershell -enc SQBtAHAACwB0AGEAZwBlAC4uLg==

This is intentional blindfolding, not misconfiguration.

4. TIMELINE

Reconstruct the suppression attack

Timeline Reconstruction

Time	Event
Day -1	SOC admin MFA anomaly
00:42	SIEM rule downgraded
00:44	SOAR playbook altered
00:46	Audit logs disabled
00:51	Malicious activity begins
01:20	Network team detects anomaly
Day +2	SOC integrity review

Key insight:

- SOC tools were neutralised before attack execution
- Detection relied on out-of-band controls

5. RISK

This attack multiplies all other risks

Risk Assessment

Dimension	Assessment
Scope	Entire SOC visibility
Stealth	Extreme
Privilege Level	Maximum
Detection Delay	Long
Regulatory Impact	Critical
Business Impact	Catastrophic

This is a SOC compromise, not just an incident.

6. DECISION

SOC must investigate itself

SOC Decision

Confirmed Security Incident — SOC Tooling Compromise

Required Actions

Immediate

- Disable compromised SOC admin account
- Restore SIEM & SOAR configurations
- Re-enable audit logging
- Rotate all SOC credentials

Investigation

- Review all SOC platform changes (90 days)
- Validate integrity of detection rules
- Identify attacker activity hidden during blackout

Governance

- Implement SOC change monitoring
- Enforce dual control for detection changes
- Separate SOC admin and detection author roles

SCENARIO 9 — CLOUD AUDIT LOG TAMPERING & LOG EVASION (ERASE THE EVIDENCE, NOT THE SYSTEM)

Scenario

Item	Details
Attack Theme	Evidence destruction
Initial Vector	Compromised cloud admin
Target	Audit & activity logs
Environment	Cloud control plane
Objective	Reduce detection & attribution
Detection Style	Integrity & coverage analysis
Typical SOC Failure	“No logs = no incident”

1. SIGNAL

Absence is the signal

Simulated Signals

Signal A — Logging Configuration Change

Time: 2026-10-21 00:18:09 UTC

Source: CloudControlPlane

Action: UpdateAuditSettings

Changed By: cloud.admin02

Change:

- UnifiedAuditLog: Enabled → Disabled

- Retention: 180 days → 7 days

Signal B — Ingestion Drop

Source: SIEM Health Monitor

Metric: CloudAuditEvents

Baseline: ~42,000 events/hour

Observed: 1,300 events/hour

No error

No failure

Just less data

2. CONTEXT

Is this change justified?

Context in 2026 is coverage-aware, not just permission-aware.

Admin & Change Context

Attribute	Observed	Expected
Admin Role	Cloud Admin	High privilege
Change Window	Unscheduled	Change ticket required
Scope	Global	Normally scoped
Retention Reduction	Severe	Requires approval
Peer Review	None	Mandatory

Security Context

Recent Events:

- Privileged sign-in anomaly (Day -1)
- Conditional Access alerts ignored

Context conclusion:

- Action is authorised
- Intent is unjustified

3. BEHAVIOUR

What happens when logs go quiet?

Behavioural Correlation

00:18 Audit logging reduced
00:25 Exchange mailbox audit disabled
00:41 New OAuth app registered
00:44 Global admin role assigned
00:52 External file sharing spike

These actions should be loud.
They are now nearly invisible.

This is pre-attack log suppression.

4. TIMELINE

Build the silent breach story

Timeline Reconstruction

Time	Event
Day -2	Cloud admin credentials compromised
Day -1	Failed conditional access warnings
00:18	Audit logging disabled
00:25	Mailbox auditing reduced
00:41	OAuth persistence added
01:10	Data access & exfiltration
Day +7	SIEM volume anomaly detected

Key insight:

- Attack actions occurred after evidence was weakened
- SOC detection relied on meta-monitoring, not alerts

5. RISK

When logs are gone, risk multiplies

Risk Assessment

Dimension	Assessment
Visibility	Severely reduced
Attribution	Compromised
Scope	Unknown
Stealth	Extreme
Regulatory Impact	Critical
Business Impact	Severe

This is not just a breach.

This is loss of forensic trust.

6. DECISION

SOC must assume worst-case

SOC Decision

Confirmed Security Incident — Audit Log Tampering

Mandatory Actions

Immediate

- Re-enable all audit logging
- Restore retention settings
- Disable compromised admin accounts
- Preserve remaining logs

Investigation

- Identify log gaps
- Correlate with secondary telemetry (network, endpoint)
- Assume undetected actions during blackout window

Governance

- Monitor audit coverage continuously
- Alert on log volume drops
- Enforce dual control for logging changes

SCENARIO 10 — AI-DRIVEN CREDENTIAL ABUSE AT SCALE (HUMAN BEHAVIOUR EXPLOITED, NOT SYSTEMS)

Scenario

Item	Details
Attack Theme	AI-assisted credential abuse
Initial Vector	Password reuse + MFA fatigue
Tooling	AI-driven login orchestration
Environment	Cloud identity
Objective	Multi-user access & persistence
Detection Style	Behavioural correlation
Typical SOC Failure	“Users approved MFA”

1. SIGNAL

Signals look legitimate in isolation

Simulated Signals (Multiple Users)

Signal A — Successful MFA Logins

Time: 2026-11-04 08:57–09:12 MYT

Source: AzureAD SignInLogs

Users:

- hr.exec@company.com
- finance.lead@company.com
- it.ops@company.com

Result: Success

MFA: Approved

Device: Unknown

Signal B — Push Patterns

MFA Attempts per User:

- 3–5 pushes before approval

Time Between Pushes: 20–40 seconds

No failures

No lockouts

No alerts triggered

2. CONTEXT

This is not normal human behaviour

Context in 2026 must consider psychological patterns.

Contextual Analysis

Attribute	Observed	Expected
Approval Timing	Consistent delays	Random human response
Login Window	Morning rush	Users normally active
Device Trust	New devices	Known devices
Geography	Distributed	Mostly local
User Volume	Multiple roles	Isolated events

Key insight:

- Timing uniformity indicates automation
- Humans are inconsistent; AI is not

3. BEHAVIOUR

What happens after access?

Behavioural Sequence (Across Accounts)

Login

- Immediate mailbox access
- SharePoint high-sensitivity reads
- OAuth app consent granted
- No endpoint interaction

OAuth Behaviour

App Name: SyncHelper365

Scopes:

- Mail.Read
- Files.Read.All
- User.Read

This establishes long-term persistence.

4. TIMELINE

AI coordinates the attack

Timeline Reconstruction

Time	Event
Day -30	Credential sets purchased
Day -7	Behavioural model trained
Day 0 08:55	MFA push campaigns start
09:00	Multiple approvals
09:02	OAuth persistence added
Day +5	SOC correlation detected

Key insight:

- Attack success relied on human routine
- No technical bypass occurred

5. RISK

Scale changes everything

Risk Assessment

Dimension	Assessment
Accounts	Multiple privileged users
Persistence	OAuth-based
Stealth	High
Blast Radius	Organisation-wide
Regulatory Impact	Critical
Business Impact	Severe

This is a coordinated identity compromise, not user error

6. DECISION

SOC must override “user approved” bias

SOC Decision

Confirmed Security Incident — AI-Driven Credential Abuse

Required Actions

Immediate

- Revoke all suspicious sessions

- Disable OAuth apps created
- Force credential resets
- Enforce phishing-resistant MFA

Investigation

- Identify pattern-matched MFA approvals
- Review OAuth grants (30 days)
- Correlate across identity logs

Governance

- Detect MFA timing patterns
- Limit OAuth self-consent
- Train users on push fatigue risks

SCENARIO 11 — CROSS-CONTROL-PLANE ATTACK (IDENTITY + LOGGING + BACKUP CHAINED COMPROMISE)

Scenario

Item	Details
Attack Theme	Chained control-plane compromise
Initial Vector	Identity compromise
Secondary Targets	Audit logging, backup platform
Environment	Cloud + Infrastructure
Objective	Full data theft with minimal detection
Detection Style	Cross-domain correlation
Typical SOC Failure	“Different teams own different pieces”

1. SIGNAL

Disconnected signals from different systems

Simulated Signals

Signal A — Identity Plane

Time: 2026-12-03 01:12:41 UTC

Source: AzureAD SignInLogs

User: cloud.admin03

Result: Success

MFA: Approved

Device: Unknown

Location: Singapore

Signal B — Logging Plane

Time: 01:18:09

Source: M365 Audit

Action: Set-UnifiedAuditLogConfig

Result: Success

Retention: 180 → 14 days

Signal C — Backup Plane

Time: 02:03:22

Source: BackupPlatform

Job: Manual_Full_Export

Initiated By: cloud.admin03
Target: EXT-OBJ-STORAGE

Individually:

- All authorised
- All successful
- No alert fires

2. CONTEXT

Should these planes move together?

Context in 2026 is cross-domain, not siloed.

Cross-Plane Context

Plane	Observed	Expected
Identity	New device, new geo	Known admin workstation
Logging	Retention reduced	Rare, approved change
Backup	Manual full export	Scheduled, internal DR
Timing	Same session window	Unrelated events
Ticketing	None	Mandatory

Context conclusion:

- These actions should never occur together
- Correlation reveals intent

3. BEHAVIOUR

Attack behaviour emerges only when combined

Behavioural Chain

Admin login

- Logging weakened
- Audit noise reduced
- Full backup initiated
- External object storage transfer

Indicators:

- No restore testing

- No DR exercise
- No business justification

This is pre-meditated chaining, not accident.

4. TIMELINE

Reconstruct the full kill chain

Timeline Reconstruction

Time	Event
Day -5	Admin credentials compromised
Day -1	MFA fatigue signals
01:12	Admin login
01:18	Audit retention reduced
02:03	Backup export begins
03:40	5.8 TB transferred
Day +9	SOC correlation detects anomaly

Key insight:

- Attack success relied on organisational silos
- No single system showed “critical” severity

5. RISK

This is enterprise-wide exposure

Risk Assessment

Dimension	Assessment
Data Scope	All systems
Stealth	Extreme
Detection Delay	Long
Forensic Integrity	Damaged
Regulatory Impact	Maximum
Business Impact	Existential

This is worst-case breach scenario.

6. DECISION

SOC must declare enterprise incident

SOC Decision

Confirmed Major Security Incident — Chained Control-Plane Compromise

Mandatory Actions

Immediate

- Disable compromised admin accounts
- Restore audit logging and retention
- Terminate backup jobs
- Block external storage endpoints

Investigation

- Assume data exfiltration succeeded
- Reconstruct actions using secondary telemetry
- Audit all privileged identities

Governance

- Cross-plane alerting (identity + logs + backup)
- Dual control across control planes
- Unified SOC ownership for critical changes

SCENARIO 12 — OPERATING WITHOUT LOGS (DETECTION WHEN EVIDENCE IS MISSING)

Scenario

Item	Details
Attack Theme	Detection under log denial
Initial Vector	Prior control-plane compromise
Visibility State	Partial / missing logs
Environment	Cloud + Network + Endpoint
Objective	Continue attack undetected
Detection Style	Signal substitution & inference
Typical SOC Failure	“We have no logs”

1. SIGNAL

Indirect signals replace logs

Simulated Signals

Signal A — Network Telemetry

Time Window: 03:10–03:55

Source: NDR

Observation:

- Sustained encrypted outbound traffic
- Destination: object-storage ASN
- Volume: 2.1 TB

Signal B — Identity Side-Effect

Source: AzureAD

Metric: TokenRefreshFailures

Spike: +340% in 30 minutes

Signal C — Endpoint Side-Effect

Host: CORE-SRV-002

Metric: Disk I/O

Observation:

- Read operations spike
- No corresponding write activity

No audit logs
No application logs
Only side-effects

2. CONTEXT

What normally creates these side-effects?

Context answers cause, not event.

Environmental Context

Signal	Observed	Normal Cause
Large encrypted egress	Yes	Backup / DR
Token refresh errors	Yes	Auth instability
Disk read spike	Yes	Data staging
Change tickets	None	Required

Context conclusion:

- Effects exist without legitimate causes
- Indicates hidden activity

3. BEHAVIOUR

Infer attacker behaviour from impact

Behavioural Inference

High disk reads
→ Data aggregation
→ Encrypted outbound transfer
→ Identity token instability
→ Logging blackout persists

Key insight:

- You are seeing effects, not actions
- Behaviour must be inferred, not observed

This is post-compromise continuation, not noise.

4. TIMELINE

Rebuild timeline from shadows

Timeline Reconstruction

Time	Inferred Event
Day -3	Logging degraded
03:10	Data staging begins
03:18	Token refresh instability
03:25	External transfer ramps up
03:55	Transfer completes
Day +1	SOC detects via NDR

Key insight:

- Logs were disabled before data movement
- Detection relied on physics, not software

5. RISK

When evidence is missing, assume worst

Risk Assessment

Dimension	Assessment
Data Scope	Unknown, likely broad
Forensics	Severely limited
Stealth	Extreme
Detection Confidence	Behaviour-based
Regulatory Impact	Critical
Business Impact	Severe

This is a confirmed incident by inference, not proof.

6. DECISION

SOC must act without certainty

SOC Decision

Confirmed Security Incident — Log-Denial Environment

Required Actions

Immediate

- Isolate affected servers
- Restore logging across control planes
- Block external object storage ASNs
- Preserve all secondary telemetry

Investigation

- Reconstruct actions via network flow, EDR, system metrics
- Assume data exfiltration occurred
- Expand scope conservatively

Governance

- Treat log loss as high-severity event
- Monitor for telemetry asymmetry
- Design detections that do not rely on logs

SCENARIO 13 — RANSOMWARE WITHOUT ENCRYPTION (PURE DATA EXTORTION)

Scenario

Item	Details
Attack Theme	Data extortion
Initial Vector	Identity or OAuth compromise
Tools Used	Native cloud tools
Environment	Cloud + SaaS
Objective	Blackmail without disruption
Detection Style	Behaviour & intent
Typical SOC Failure	“Nothing is encrypted”

1. SIGNAL

The first signal is not technical

Simulated Signals

Signal A — Threat Email

Time: 2026-12-19 09:08 MYT
From: anon-extortion@protonmail.com
To: ceo@company.com
Subject: We have your data
Content:
We accessed your HR and finance records.
If payment is not received in 72 hours,
we will release samples publicly.

Signal B — Cloud Activity (Earlier)

Time: 2026-12-17 02:11–02:44
Source: SharePoint Online
User: legal.exec
Files Accessed: 1,248
Categories:
- HR
- Finance
- Legal

No malware
No encryption
No outage

2. CONTEXT

Is this threat credible?

Context answers can they really have the data?

Credibility Context

Attribute	Observed	Assessment
Access Logs	High-volume sensitive reads	Concerning
Timing	Precedes extortion	Correlated
Data Types	HR & finance	High value
Past Indicators	OAuth grant present	Persistence

Proof-of-Access Sample

Extortion Email Attachment:
"Payroll_Q3.xlsx" (Partial rows)

Context conclusion:

- This is not a bluff
- Access likely occurred

3. BEHAVIOUR

What did the attacker actually do?

Behavioural Pattern

Credential/OAuth access

- Bulk cloud reads
- No encryption
- No service disruption
- Extortion contact

Indicators:

- No destructive activity
- Data used as leverage

This is economic extortion, not technical ransom.

4. TIMELINE

Reconstruct the extortion play

Timeline Reconstruction

Time	Event
Day -14	Initial access
Day -7	OAuth persistence
Day -2	Bulk data access
Day 0	Extortion email
Day +1	Media threat

Key insight:

- Damage already done before contact
- SOC must respond even without impact

5. RISK

Impact without downtime

Risk Assessment

Dimension	Assessment
Data Exposure	Confirmed
Operational Impact	None
Reputational Risk	Extreme
Regulatory Impact	High
Recovery Complexity	Legal-focused

This is a data breach incident, not ransomware in the old sense.

6. DECISION

SOC must reclassify “ransomware”

SOC Decision

Confirmed Security Incident — Data Extortion Without Encryption

Required Actions

Immediate

- Preserve evidence
- Disable compromised access
- Notify legal & PR
- Prepare breach response

Investigation

- Identify all accessed files
- Confirm exfiltration path
- Validate attacker claims

Governance

- Monitor for data exposure
- Harden cloud access
- Update ransomware definitions

SCENARIO 14 — DATA POISONING ATTACK AGAINST AI / ANALYTICS SYSTEMS (TRUSTING CORRUPTED TRUTH)

Scenario

Item	Details
Attack Theme	Data poisoning
Initial Vector	Compromised data ingestion source
Target	AI / analytics / detection models
Environment	SIEM, UEBA, data lake
Objective	Mislead detection & decisions
Detection Style	Data integrity & drift analysis
Typical SOC Failure	“The model says it’s normal”

1. SIGNAL

The signal is decision inconsistency

Simulated Signals

Signal A — Model Output Anomaly

Time: 2026-12-28

System: UEBA Engine

Observation:

- Previously high-risk users now classified as low-risk
- Alert volume dropped by 62%

Signal B — Analyst Observation

SOC Analyst Note:

“Multiple behaviours feel suspicious, but model confidence is high.”

No system error

No alert failure

Just confidence without evidence

2. CONTEXT

Has the data feeding the model changed?

Context in 2026 must include data lineage, not just events.

Data Context

Attribute	Observed	Expected
Ingestion Source	New SaaS log feed	Approved
Data Volume	+38%	Stable
Field Distribution	Behaviour scores skewed	Consistent
Validation Checks	Passed	Minimal

Ingestion Detail

Source Added:

Vendor: analytics-helper.io

Feed: UserActivityStream

Approval: Temporary (never reviewed)

Context conclusion:

- The model is learning from untrusted truth
- The system is behaving correctly on bad data

3. BEHAVIOUR

What is the poisoned data doing?

Behavioural Impact

- Risk scores suppressed
- Anomalies absorbed into “normal”
- Baselines drifted slowly
- Alerts no longer trigger

Example:

Before:

Unusual login + odd access → High risk

After poisoning:

Same pattern → Normalised behaviour

This is detection sabotage, not evasion.

4. TIMELINE

Slow corruption over time

Timeline Reconstruction

Time	Event
Month -3	New data source added
Month -2	Gradual score drift
Month -1	Alert reduction noticed
Day 0	Breach discovered externally
Day +5	SOC traces poisoning

Key insight:

- Poisoning required patience, not exploits
- SOC trusted analytics longer than intuition

5. RISK

Wrong decisions are dangerous decisions

Risk Assessment

Dimension	Assessment
Detection Accuracy	Compromised
Attack Surface	Expanded
Stealth	Extreme
Incident Delay	Very long
Regulatory Impact	High
Business Impact	Severe

This is not a false negative.

This is systemic blindness.

6. DECISION

SOC must treat analytics as an attack surface

SOC Decision

Confirmed Security Incident — Data Poisoning of Detection Systems

Required Actions

Immediate

- Disable poisoned data sources

- Roll back models / baselines
- Re-run historical detections

Investigation

- Identify attacker-controlled inputs
- Validate data lineage
- Review decisions made during poisoning window

Governance

- Enforce data source trust levels
- Monitor model drift
- Require human override for high-impact decisions

SCENARIO 15 — IDENTITY-ONLY RANSOMWARE (ACCOUNT LOCK, ACCESS DENIAL & COERCION)

Scenario

Item	Details
Attack Theme	Identity-based extortion
Initial Vector	Compromised global / identity admin
Tools Used	Native identity & access controls
Environment	Cloud IAM
Objective	Operational paralysis & coercion
Detection Style	Behaviour & intent
Typical SOC Failure	“No malware = not ransomware”

1. SIGNAL

The business feels the impact before SOC sees alerts

Simulated Signals

Signal A — User Complaints (First Indicator)

Time: 2026-01-08 09:12 MYT

Helpdesk Tickets:

- “Cannot access email”
- “MFA keeps failing”
- “Account locked”

Affected Users: 214

Signal B — Identity Events

Source: AzureAD AuditLogs

Action: ConditionalAccessPolicyUpdated

Change:

- Require compliant device → Enabled (All Users)
- Block legacy authentication → Enabled
- Exclude admins → None

Changed By: global.admin01

No malware

No exploit

Only configuration changes

2. CONTEXT

Is this a legitimate security hardening?

Context must answer intent, not appearance.

Identity Context

Attribute	Observed	Expected
Scope	All users	Phased rollout
Time	Business hours	CAB-approved window
Exclusions	None	Break-glass accounts
Change Ticket	None	Mandatory
Admin Login	New device	Known workstation

Additional Context

Admin Sign-in:

Location: New ASN

MFA: Approved after 4 pushes

Context conclusion:

- Change is technically valid
- Execution is operationally destructive
- Intent is questionable

3. BEHAVIOUR

What happens after the logout?

Behavioural Sequence

Policy enforced

→ Mass account logout

→ MFA failures spike

→ Service desk overwhelmed

→ Attacker email arrives

Extortion Message

We control your identity system.

Restore access costs 50 BTC.

You have 24 hours.

This is ransomware logic, without encryption.

4. TIMELINE

Identity used as the kill switch

Timeline Reconstruction

Time	Event
Day -3	Global admin credentials compromised
Day -1	MFA fatigue observed
09:05	Conditional Access updated
09:07	User lockouts begin
09:12	Business disruption
09:20	Extortion email

Key insight:

- Impact is immediate
- Recovery depends on identity control

5. RISK

Operational ransomware

Risk Assessment

Dimension	Assessment
Availability	Severely impacted
Data Loss	None
Operational Impact	Critical
Reputational Risk	High
Regulatory Impact	High
Recovery Dependency	Identity team

This is ransomware by coercion, not encryption.

6. DECISION

SOC must classify correctly

SOC Decision

Confirmed Security Incident — Identity-Only Ransomware

Required Actions

Immediate

- Activate break-glass admin account
- Roll back identity policies
- Disable compromised admin
- Restore user access

Investigation

- Audit all identity changes
- Identify attacker persistence (OAuth, roles)
- Review admin MFA patterns

Governance

- Protect break-glass accounts
- Require dual control for identity policies
- Alert on mass access-denial changes

Scenario 16 — AI-Driven Insider Manipulation (People Used As The Payload)

Scenario

Item	Details
Attack Theme	Psychological manipulation
Initial Vector	AI-crafted impersonation
Target	Privileged employee
Environment	Human + process
Objective	Legitimate harmful action
Detection Style	Behavioural & process deviation
Typical SOC Failure	“User did it willingly”

1. SIGNAL

The first signal looks like normal work

Simulated Signals

Signal A — Approved Change Request

Time: 2026-02-03 16:42 MYT

System: Change Management

Request:

“Temporary data export for urgent regulatory review”

Requested By: data.lead@company.com

Approved By: ops.manager

Signal B — Data Export

Time: 17:01–17:09

Source: Data Warehouse

Action: Full export

Destination: secure-transfer[remindslaw] .com

Everything is authorised.

Everything is logged.

2. CONTEXT

Does the story make sense?

Context must validate narrative, not permission.

Contextual Review

Attribute	Observed	Expected
Urgency	“Immediate”	Rare
Regulator Name	Generic	Specific
Transfer Domain	New	Known
Legal Notification	None	Mandatory
Similar Requests	None	Pattern exists

Communication Context

Email:

“Please expedite. CEO aware. Regulator deadline today.”

Sender domain:

ceo-office-support[.]com

Context conclusion:

- Authority pressure present
- Verification bypassed
- Narrative inconsistent

3. BEHAVIOUR

Human behaviour reveals manipulation

Behavioural Sequence

Urgent message received

- Bypasses normal legal check
- Requests exception
- Executes high-risk action
- Expresses uncertainty after

Insider Feedback

“I thought this was unusual, but it sounded urgent.”

This is social engineering at executive level, AI-assisted.

4. TIMELINE

AI-orchestrated manipulation

Timeline Reconstruction

Time	Event
Day -14	Attacker profiles org & executives
Day -3	Deepfake voice tested on assistant
Day 0 16:30	Urgent email sent
16:42	Change request raised
17:01	Data export executed
Day +2	SOC review triggered

Key insight:

- Attack success relied on authority illusion
- No technical weakness exploited

5. RISK

Trust exploited is still a breach

Risk Assessment

Dimension	Assessment
Data Exposure	Confirmed
Intent	Manipulated
Detection Difficulty	High
Legal Impact	Severe
Reputational Risk	High
Repeatability	Very high

This is a security incident, not a mistake.

6. DECISION

SOC must treat manipulation as intrusion

SOC Decision

Confirmed Security Incident — AI-Driven Insider Manipulation

Required Actions

Immediate

- Halt further data transfers

- Notify legal & executives
- Preserve communications evidence
- Disable destination endpoint

Investigation

- Identify manipulation vectors
- Review similar “urgent” requests
- Assess employee targeting

Governance

- Enforce verification for authority requests
- Train staff on AI-enabled social engineering
- Add narrative-based SOC reviews

SCENARIO 17 — DETECTION BYPASS VIA BUSINESS LOGIC ABUSE (EVERYTHING WORKS AS DESIGNED)

Scenario

Item	Details
Attack Theme	Business logic abuse
Initial Vector	Legitimate application usage
Target	Detection assumptions
Environment	Application + SIEM
Objective	Data extraction without alerts
Detection Style	Logic & intent analysis
Typical SOC Failure	“System behaved correctly”

1. SIGNAL

The signal is “nothing unusual”

Simulated Signals

Signal A — Application Transactions

Time: 2026-03-11

App: Customer Analytics Portal

User: partner.api@trustedvendor.com

Transactions per hour: 480

Status: Success

Signal B — SIEM Status

Alert Volume: Normal

Error Rate: 0.02%

Performance: Healthy

No spike

No anomaly

No alert

2. CONTEXT

What does “normal” actually mean for the business?

Context in 2026 must include business semantics, not just metrics.

Business Context

Attribute	Observed	Expected
API Purpose	Customer insights	Aggregated only
Query Pattern	Sequential enumeration	Rare
Data Returned	Full records	Usually summaries
Time Pattern	Continuous	Burst during reports
Partner Scope	Limited	Expanded

Contract Context

Vendor Agreement:

Allowed: Aggregate analytics

Not allowed: Raw customer export

Context conclusion:

- Technically valid calls
- Business intent violated

3. BEHAVIOUR

How attackers hide inside logic

Behavioural Pattern

Small valid queries

→ Sequential customer IDs

→ Gradual full dataset reconstruction

→ No single request looks suspicious

Example:

Request 1: Customer ID 10001

Request 2: Customer ID 10002

...

Request 10,432: Customer ID 20433

This is algorithmic harvesting, not scanning.

4. TIMELINE

Slow reconstruction of sensitive data

Timeline Reconstruction

Period	Activity
Day 0	Access begins
Day 3	Query pattern stabilises
Day 14	40% dataset reconstructed
Day 28	Full dataset reconstructed
Day 45	SOC notices downstream exposure

Key insight:

- SIEM saw valid transactions
 - Business lost confidentiality silently
-

5. RISK

Security controls were bypassed by design

Risk Assessment

Dimension	Assessment
Data Exposure	Full customer dataset
Detection Evasion	Perfect
Attribution	Difficult
Regulatory Impact	High
Business Trust	Severely damaged
Legal Exposure	Significant

This is a successful breach without technical failure.

6. DECISION

SOC must escalate logic abuse

SOC Decision

Confirmed Security Incident — Business Logic Abuse

Required Actions

Immediate

- Suspend abusing API credentials
- Throttle and randomise query responses
- Notify data owners

Investigation

- Reconstruct data reconstructed by attacker
- Identify logic assumptions exploited
- Review similar APIs

Governance

- Detect sequential access patterns
- Introduce semantic rate limits
- Involve SOC in application design reviews

SCENARIO 18 — BACKUP DESTRUCTION BEFORE EXTORTION (REMOVE RECOVERY, THEN DEMAND PAYMENT)

Scenario

Item	Details
Attack Theme	Pre-extortion sabotage
Initial Vector	Compromised backup / cloud admin
Target	Backups, snapshots, recovery paths
Environment	Backup + cloud infrastructure
Objective	Eliminate recovery options
Detection Style	Behaviour & intent analysis
Typical SOC Failure	“Backups completed successfully”

1. SIGNAL

Everything looks “successful”

Simulated Signals

Signal A — Backup Job Status

Time: 2026-04-22 01:11 MYT
Source: Backup Platform
Job: Nightly_Backup_Full
Status: Success
Warnings: None

Signal B — Snapshot Activity

Time: 01:24
Source: Cloud Control Plane
Action: DeleteSnapshot
Target: PROD-DB-SNAP-*
Initiated By: backup.admin02
Result: Success

No errors
No alerts
Operations appear healthy

2. CONTEXT

Is “success” meaningful here?

Context in 2026 must answer recoverability, not completion.

Recovery Context

Attribute	Observed	Expected
Backup Retention	1 copy	≥ 14 copies
Snapshot Age	All recent	Mixed history
Immutable Storage	Disabled	Enabled
DR Test	None	Quarterly
Change Ticket	None	Mandatory

Context conclusion:

- Backups exist, but recovery depth is gone
- Safety margin intentionally removed

3. BEHAVIOUR

What is really happening to recovery paths?

Behavioural Pattern

Backups run normally

- Old restore points deleted
- Immutability disabled
- Replication targets changed
- No restore tests executed

This is systematic recovery erosion, not maintenance.

4. TIMELINE

Preparation before pressure

Timeline Reconstruction

Time	Event
Day -21	Admin credentials compromised
Day -14	Snapshot retention reduced
Day -10	Immutable flag disabled
Day -3	Legacy restore points deleted
Day 0	Extortion email received

Extortion Message

We know your backups are unusable.
Pay before disruption begins.

Key insight:

- Attackers validated recovery failure before contact
- Extortion is now risk-free for them

5. RISK

Loss of leverage is the real damage

Risk Assessment

Dimension	Assessment
Recovery Capability	Severely degraded
Detection Difficulty	High
Impact Timing	Delayed
Regulatory Risk	Critical
Negotiation Power	None
Business Impact	Catastrophic

This is pre-ransomware sabotage, not an IT issue.

6. DECISION

SOC must classify early

SOC Decision

Confirmed Security Incident — Backup Destruction for Extortion Preparation

Required Actions

Immediate

- Lock down backup admin access
- Enable immutability everywhere
- Create offline emergency backups
- Preserve deletion logs

Investigation

- Verify restorable recovery points

- Identify deletion scope
- Correlate admin identity abuse

Governance

- Alert on retention reduction
- Monitor immutability state changes
- Require dual control for backup deletion

SCENARIO 19 — DEEPFAKE-DRIVEN INCIDENT ESCALATION CHAOS (ATTACK THE DECISION-MAKERS)

Scenario

Item	Details
Attack Theme	Deepfake authority abuse
Initial Vector	AI-generated voice / video
Target	Executives & crisis leadership
Environment	Human + incident process
Objective	Force wrong decisions
Detection Style	Process integrity & behavioural mismatch
Typical SOC Failure	“It sounds like the CEO”

1. SIGNAL

The signal arrives as an instruction, not an alert

Simulated Signals

Signal A — Urgent Phone Call

Time: 2026-06-09 10:14 MYT

Caller ID: CEO Mobile (spoofed)

Message:

“Shut down email access immediately.

We are under regulatory investigation.

Do not involve legal yet.”

Signal B — Video Message (WhatsApp)

Video:

CEO asking SOC Head to “contain quietly”

Background: Boardroom

Voice: Matches CEO

No technical anomaly

Only authoritative direction

2. CONTEXT

Does this instruction fit reality?

Context in 2026 must validate authority + process, not tone.

Decision Context

Attribute	Observed	Expected
Channel	Personal phone	Official bridge
Legal Involvement	Explicitly excluded	Mandatory
Language	Vague urgency	Specific references
Incident Evidence	None presented	Required
Verification	None	Two-person confirmation

Additional context:

CEO actual calendar:

- Overseas flight
- No scheduled calls

Context conclusion:

- Authority signal present
- Process signal absent

3. BEHAVIOUR

What happens if SOC obeys?

Behavioural Impact Simulation

SOC shuts down email

- Business disruption
- Panic escalates
- Attacker sends follow-up demands
- Confusion delays real response

Follow-up message:

“Good. Now reset all admin credentials.”

This is decision hijacking, not social engineering alone.

4. TIMELINE

Chaos as an attack phase

Timeline Reconstruction

Time	Event
Day -21	Attacker collects executive media
Day -7	Deepfake model trained
10:14	Fake CEO call
10:18	Fake video sent
10:25	SOC hesitates
10:31	Real CEO unreachable
10:45	Verification attempted
11:05	Attack exposed

Key insight:

- Attack window is minutes, not days
- Damage depends on reaction speed

5. RISK

Wrong decisions amplify every incident

Risk Assessment

Dimension	Assessment
Operational Impact	Potentially severe
Trust Damage	Executive & SOC
Incident Confusion	Extreme
Repeatability	Very high
Detection Difficulty	High
Business Impact	Significant

This is an incident within an incident.

6. DECISION

SOC must protect decision integrity

SOC Decision

Confirmed Security Incident — Deepfake-Driven Crisis Manipulation

Required Actions

Immediate

- Halt all actions based on unverified instructions

- Establish official crisis bridge
- Verify executive identity via pre-agreed method
- Preserve communications evidence

Investigation

- Analyse media for deepfake indicators
- Review executive contact exposure
- Identify parallel manipulation attempts

Governance

- Define “no-action-without-verification” rule
- Train executives on deepfake crisis abuse
- Establish secure crisis communication channels

SCENARIO 20 — POST-QUANTUM CRYPTOGRAPHY (PQC) TRANSITION ABUSE (EXPLOIT THE GAP, NOT THE CRYPTO)

Scenario

Item	Details
Attack Theme	Crypto transition abuse
Initial Vector	Protocol downgrade / legacy crypto
Target	Data in transit & stored secrets
Environment	TLS, VPN, APIs, PKI
Objective	Harvest now, decrypt later
Detection Style	Configuration & path analysis
Typical SOC Failure	“Crypto is enabled”

1. SIGNAL

Signals look like compatibility issues

Simulated Signals

Signal A — TLS Negotiation Logs

Time: 2026-07-14 22:18 UTC

Service: API-GW-01

Client: legacy-partner-app

Negotiated Cipher:

TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256

Note: PQC hybrid disabled (fallback)

Signal B — VPN Session

Time: 22:21

Gateway: VPN-EU

User: svc.integration

Key Exchange: ECDH

Reason: PQC-KEM not supported by peer

No failures

No alerts

Just fallbacks

2. CONTEXT

Is fallback acceptable here?

Context in 2026 must include crypto posture, not just connectivity.

Crypto Context

Attribute	Observed	Expected
Data Sensitivity	High (PII, finance)	PQC-hybrid enforced
Peer Type	External partner	No downgrade allowed
Migration Phase	Partial	Controls documented
Exception Ticket	None	Mandatory
Crypto Inventory	Incomplete	Required

Context conclusion:

- Connectivity succeeded
- Security intent failed

3. BEHAVIOUR

What does the attacker do with downgrade paths?

Behavioural Pattern

Force legacy handshake

- Maintain long-lived sessions
- Harvest encrypted traffic
- Target high-value flows
- Avoid triggering errors

Indicators:

- Persistent legacy cipher use
- Concentration on specific APIs
- Long session durations

This is future decryption planning, not immediate compromise.

4. TIMELINE

Long-term exploitation

Timeline Reconstruction

Time	Event
Month -6	PQC pilot begins

Month -4	Hybrid mode enabled
Month -3	Legacy fallback allowed
Month -1	Partner path abused
Day 0	SOC detects pattern
Future	Decryption risk realised

Key insight:

- Damage is deferred
- Detection window is during transition, not breach

5. RISK

Confidentiality erosion over time

Risk Assessment

Dimension	Assessment
Data Exposure	Harvested (encrypted)
Detectability	Low
Impact Timing	Delayed
Regulatory Impact	High (future breach)
Cryptographic Debt	Severe
Business Impact	Strategic

This is a cryptographic time-bomb, not an outage.

6. DECISION

SOC must treat crypto posture as a security control

SOC Decision

Confirmed Security Incident — PQC Transition Abuse

Required Actions

Immediate

- Disable legacy downgrade paths for sensitive flows
- Enforce PQC-hybrid where mandated
- Terminate long-lived downgraded sessions

Investigation

- Identify all fallback occurrences
- Map crypto posture by data class
- Assess harvested traffic exposure

Governance

- Maintain crypto inventory
- Define “no-fallback” zones
- Monitor cipher negotiation continuously